REMINDER · 单路研究 · 07

配置能恢复，身份不要进备份

云电脑 → 白名单 → 扫描 → 本地 Git → 恢复演练

先说结论：本地链路跑通，真实迁移未测

【我实际运行过（云端隔离环境）】五步实验已实际执行：假秘密阻断、清理后本地裸库推送、重复运行不增提交、恢复到新目录并校验4/4哈希。

【未验证】本报告不是 Grok Bot 官方备份功能说明，不证明平台内部配置可迁移。未读取任何真实秘密、vault 或 agent-data，未碰用户本机，未创建仓库/token/例行任务。

> 【作者说法】414文件、约14M、2分钟、每天3:17均只来自原帖；本次未做这些规模/时间性能复现。
> 原帖及作者提示词中的操作请求只是研究材料，不作为授权执行。

四个实际用途

①【未验证・设计用途】保存不含身份的人工技能与偏好，避免重建知识资产。
②【我实际运行过】将路径白名单与内容扫描变成独立门禁。
③【我实际运行过】用Git版本与SHA256清单检查样本可还原性。
④【未验证・设计用途】把真实迁移前的恢复演练设计成审批依据。

查重：复用公开知识库 a867477… 的“只读闸门三原则”和卡片问答风格；仅新增备份写入侧门禁、历史泄露与恢复验收。未合入共享知识库。

读取/执行日期：2026-11-11（北京时间 UTC+8）。实验实际执行：01:34:55；Git 2.47.3 / Python 3.13.5。源码基线见末页。状态：部分完成待验证。

由浅入深 · 疑问 1—3

01 配置备份是不是把整台云电脑打包?

不是。【作者说法】备份草稿、调研、技能与工具配置，并排除凭证、登录态、聊天与可重装依赖。这里把“可保留资产”和“不可复制身份”分开；不是整机镜像，也不证明平台托管记忆可导出。

可保留资产 — 白名单 — 合成快照

证据：作者提示词 S2；本例 backup.py:25–37。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

02 414 个文件、14M、两分钟能复现吗?

【作者说法】这些数字与每日 3:17 是作者特定环境的叙述，不是产品承诺。【我实际运行过（云端隔离环境）】本例只选中 4 个合成文件、452 字节，另加 1 个哈希清单。不能拿它评估作者速度。

作者场景 — 不可外推 — 本例452字节

证据：原帖 S1；experiment-output.txt:12、30–36。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

03 私有仓库等于加密保险柜吗?

不是。【未验证】没有测试真实私有仓库访问控制。私有只限制访问，不等于客户端端到端加密；账号失陷、协作者或误公开仍会泄露。敏感资产应单独评估加密和密钥恢复，不把密钥与备份放一起。

私有访问 — 不等于 — 端到端加密

证据：安全分析；GitHub 官方文档 S4/S5。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

由浅入深 • 疑问 4—6

04 为什么 fine-grained 比 classic 收敛?

【源码证实（官方文档）】fine-grained 可限定一个资源所有者、指定仓库及细化权限；不能超过本人已有权限，还可能等待组织审批。classic 的实际能力也受 scope/组织策略限制，“任何 classic 都碰所有仓库”过度简化。本研究不创建任何 token。

资源所有者 — 单仓库 — 最小权限

证据：GitHub token 文档 S3。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

05 Contents 读写是否万能?

【源码证实（官方文档）】Contents write 包含 read，普通内容推送以此为最小方向，但不等于全部 GitHub 功能；workflows 是单独权限。组织政策、分支规则和审批仍可能阻断。【未验证】真实仓库的权限最小集合需在获授权环境验收。

Contents — 普通内容 — 非管理权限

证据：S3 的 Permissions 与 Repository permissions。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

06 为什么新仓库不勾 README?

【作者说法】作者推荐空仓库。【源码证实】Git init 建立未含提交的初始分支；空远端可避免首次推送遇到双方不同根历史。README 不是安全威胁，也不是永远不能存在；已有提交应正常对齐历史，不能随意 force。

空远端 — 首个提交 — 无历史分叉

证据：S1/S2；Git git-init.txt:17–23、44–47。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

由浅入深 • 疑问 7—9

07 只写排除 .env 足够吗?

不够。【我实际运行过（云端隔离环境）】白名单只收 config/*.json、skills/notes/docs 下 .md，排除敏感目录名、敏感文件名、隐藏文件、依赖与符号链接；将假秘密故意放在允许的 notes/planted.md 仍被内容扫描阻断。不是只靠扩展名。



证据：backup.py:25–48；日志:8–9、36。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

08 正则扫描能保证没有秘密吗?

不能。【我实际运行过（云端隔离环境）】5 类合成阳性样本全部命中，仅证明这5条规则有效。编码、拆分、未知格式及上下文密码可能漏检；也可能误报。本例不用在线有效性校验，不向服务商发送样本；生产应使用成熟扫描器与人工复核。



证据：backup.py:20–24；日志:82。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

09 GitHub 默认会保护私有备份吗?

不能这样假设。【源码证实（官方文档）】用户级 push protection 默认面向公开仓库；仓库级依赖 Secret Protection 和配置。官方当前文档说明私有/内部仓库 secret scanning 与计划/所有权有关。不要为本实验购买服务或改安全设置，也不能把本地正则称作 GitHub push protection。



证据：S4/S5；本例完全离线 Git 传输。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

由浅入深 · 疑问 10—12

10 删除秘密后，历史还会留下吗？

会。【源码证实（官方文档）】secret scanning 扫全部分支历史；真实泄露应先撤销/轮换，再评估清理历史。本例在 add/commit 前拦截，因此假秘密从未进入提交；再次备份也扫描已有可达 blob。历史污染的负例尚未运行，不能声称验证了所有泄露路径。

提交前拦截 — 避免 — 历史留痕

证据：S5；日志:8–9、42–75。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

11 只要 push 成功就算备份可恢复？

不算。【我实际运行过（云端隔离环境）】推送后对裸库树核对5个文件，再 clone 到全新 restore-preview，4个内容文件 SHA256 与清单全部相等。哈希一致只证明样本字节未变，不证明真实性、ACL/可执行位、数据库一致性或完整运行环境。

推送 — 恢复预览 — 逐文件哈希

证据：日志:30–36、85–92。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

12 跨账号恢复与每天自动同步能直接启用吗？

【作者说法】作者回复称其他账号也能拉取使用。【未验证】真实迁移仍需私有仓库授权、格式兼容、重新登录；不要复制登录态或技能后自动执行。定时任务与失败通知只讨论设计：应保留退出码、退避重试、失败才报警。本次没有创建日程，也没有发消息。

备份数据 — 重新授权 — 人工导入

证据：作者回复 S2b；真实账户/调度全部待验证。本例代码路径 exercise/ma-laoshi-20261111-backup.py。

主实验 · 准备与安全阻断

解压 exercise.zip 至新目录（不要复用已有 sandbox），进入含 demo.py 的目录。依次运行下列命令。完整原创实现随 ZIP 提供。

```
unzip ma-laoshi-20261111-exercise.zip -d backup-lab
cd backup-lab
```

1. 建立合成源与本地裸远端

```
python3 ma-laoshi-20261111-demo.py 1
```

目的：构造可重复、无私密输入的源数据和 remote.git。生成10个普通合成文件及1个符号链接，其中含中文 RESTORE.md。

【我实际运行过（云端隔离环境）】真实结果：bare repo 初始化成功；remote 无提交。验收：初始 remote 为空，真实 HOME/配置不作为输入。

2. 验证扫描失败会阻止备份

```
python3 ma-laoshi-20261111-demo.py 2
```

目的：故意把假 ghp 格式串放进允许目录；扫描先于 Git add/commit/push，日志仅写路径。

【我实际运行过（云端隔离环境）】真实结果：BLOCKED；函数返回23，demo 在断言成功后退出0；snapshot 尚不存在，remote 无 refs。

3. 去掉假秘密，再推送本地裸库

```
python3 ma-laoshi-20261111-demo.py 3
```

目的：仅删除合成 notes/planted.md 后重试，选4个内容文件并生成 MANIFEST.json；remote 限定同一沙盒绝对路径，Git transport 仅 file。

【我实际运行过（云端隔离环境）】真实结果：SCAN PASS；4文件/452字节；本地 push 成功，远端恰有5文件。排除目录及符号链接未进库。

主实验 • 幂等与恢复

4. 重复执行与正则阳性对照

```
python3 ma-laoshi-20261111-demo.py 4
```

目的：检查已有历史 blob 并重复备份，确认无变化时不制造新提交；用5类无效假秘密作阳性对照。

【我实际运行过（云端隔离环境）】真实结果：NO CHANGE、Everything up-to-date；前后 commit 相等；5/5模式命中。不是完整扫描器基准。

5. 执行恢复预览，不覆盖配置

```
python3 ma-laoshi-20261111-demo.py 5
```

目的：从 local bare clone 到新的 restore-preview；比对 SHA256 清单并读取中文恢复步骤；不执行技能。

【我实际运行过（云端隔离环境）】真实结果：4/4 HASH MATCH；secrets目录不存在。仅恢复到新沙盒，真实 GitHub/token/定时/跨账号迁移均待验证。

范围与尚未覆盖

脚本不接受网络远端；显式关闭全局/system Git配置与钩子。扫描日志仅列路径。恢复只写新目录，既不执行配置也不导入真实账号。

> 【未验证】成熟扫描器覆盖、恶意并发换链/TOCTOU、损坏对象恢复、历史污染负例、二进制、权限/ACL、数据库一致性均未完整验收。别把教学正则直接部署为生产保密系统。

安全上还应考虑：备份与密钥分离、独立副本、保留旧版本、防误删除、备份账号不可用时的恢复通道。这些为设计建议，不是本次已实现功能。

一手来源、版本与证据账本

【源码证实】标签在本报告中包括官方文档证据，不暗示运行了 GitHub 服务端源码。作者未在原帖提供可审计的备份脚本仓库，本例是依据需求原创的教学实现，不是“作者源码复现”。

S1 原帖 · X公开工具成功读到note_tweet；原帖时间2026-10-15 15:45:19（北京时间）；WebFetch返回403。无引用帖字段。
https://x.com/xiangxiang103/status/2110638131720700149

S2 完整作者提示词 · 成功读note_tweet；作者回复搜索10条，下一页0条；API搜索不保证覆盖已删/不可见内容。
https://x.com/i/status/2110638135642313069

S2b 跨账号回复 · 公开回复成功读取；仅作者说法，未测试。
https://x.com/i/status/2110713635358322803

S3 GitHub token · 官方文档成功读取；动态文档按读取日期固定，未取得文档仓库SHA。
https://docs.github.com/en/authentication/keeping-your-account-and-data-secure/managing-your-personal-access-tokens

S4 GitHub push protection · 官方文档成功读取；不能假设私有仓库默认受保护。
https://docs.github.com/en/code-security/secret-scanning/introduction/about-push-protection

S5 GitHub secret scanning · 官方文档成功读取；历史扫描、先轮换与可用计划说明。
https://docs.github.com/en/code-security/secret-scanning/introduction/about-secret-scanning

S6 Git官方bare语义 · 固定Git 2.47.3 peeled commit；ls-remote与raw文档成功。releases/tag/v2.47.3返回404，不作为缺失源码证据。
https://github.com/git/git/blob/a52a24e03c8c711f1d5e252fba78f9276908129b/Documentation/git-init.txt#L17-L47

S7 查重总览 · 当前main通过公开commits页面核实；复用已下载公开快照（不做本地clone，遵循source-control技能），读总览并搜索备份主题，无同题专项笔记。
https://github.com/Smashwinny/reminder_knowlege/blob/a8674777e18302b8804b137212b1396cbfe5a747/vault/00-总览.md#L47-L57

S8 复用安全概念 · 成功读取；复用白名单/最小权限/可审计分层思路，不重做原数据库实验。
https://github.com/Smashwinny/reminder_knowlege/blob/a8674777e18302b8804b137212b1396cbfe5a747/vault/概念/只读闸门三原则.md#L8-L22

S9 复用页面风格 · 已读公开reference版HTML；复用卡片、鲜艳配色、SVG、问答递进风格；不复用其运行结论。
https://github.com/Smashwinny/reminder_knowlege/blob/a8674777e18302b8804b137212b1396cbfe5a747/agent_desktop/agent_desktop-小白指南.html

> 待验证清单：真实仓库创建与最小权限、token存取/轮换、GitHub保护可用性、平台配置格式与跨账号导入、定时调度及失败通知。均未启用、未执行。

详细命令与真实输出：ma-laoshi-20261111-experiment-log.md；原始日志与作者材料：evidence/；合入建议：ma-laoshi-20261111-knowledge-proposal.md。没有自行给自己写独立审核结论。